# ORION ComplianceCore

STEP 2 | RELEASE & OPERATIONAL RUNBOOK

26 October 2026 • Local review candidate • Production change pending approval

## Release decision and boundary

The existing ComplianceCore application has been upgraded in place as a local release candidate. The architecture, ORION branding, existing master records, tenants, users, authentication and billing arrangements are retained. No deployment, production migration, live payment or customer-record write was performed for Step 2. Cloud database access for the backup was read-only.

This implements the approved Step 1 backlog. The user’s direct requirements govern terminology: compliance assessment, stakeholder engagement, risk assessment, policy templates and later, framework-appropriate applicability/SoA. There is no separate gap-assessment module. Internal legacy implementation table/API names remain for compatibility.

The adopted prompt says: “Do not modify production data without explicit approval.” Production schema, runtime credential/configuration and deployment changes remain pending that approval. This pack provides the concrete source, test evidence and operating instructions to review first.

This is a tested release candidate. It is not a certification, legal opinion, penetration test or claim that every provider integration is production-ready. Environment-specific acceptance and security limitations are recorded below.

## Changes and reused components

Navigation and dashboards reuse AppShell, existing routes, roles and module pages. Permission-aware actions, contextual help, named record pickers with server search, stable source links, pagination and four operational work queues connect the modules. Personal security settings remain accessible across roles.

Framework assessment reuses framework_implementations and controls. Stakeholder consultation records scope, responsibilities and named assets. The worksheet uses the existing risks master and cross-framework control links. Real XLSX export separates consultation, risks and method. Human confirmation is required for suggestions. Scope, reviewed duties, risk assessment and treatment precede final applicability. ISO certification, SOC attestation, PCI validation and monitoring profiles are distinguished.

Policies reuse policies, policy_versions and approvals. Ten editable Word policy templates support tailored drafts, independent approval and publication. Reader assignments reference an exact published version, deduplicate repeated assignments and reject superseded-version acknowledgements.

The absent obligations register and approved source snapshots add source URL/edition, jurisdiction, sector, last verification, optional verified effective date, applicability facts, accountable owner, deadline and review date. Revised sources return to review. Independent human approval is required before activation; no automatic legal conclusions or silent replacement of approved source versions was introduced.

Dated control workpapers link existing controls and evidence. They retain criteria, sample, method, outcome, tester, control snapshot and evidence versions. Independent review and freshness checks prevent a changed control/file or unreviewed status from counting as current assurance.

Existing audits, findings and tasks remain their masters. Findings link actual controls/tests; audit completion requires a reviewed current report. CAPA extends tasks with root cause, correction, prevention, effectiveness criteria and version-pinned proof. Another reviewer verifies effectiveness. Failed review reopens linked findings or incidents; task comments retain the review. Finding closure needs effective linked corrective work and exact closure proof.

Vendor questionnaires extend existing vendors with answers, proof, independent review and expiry. Training completion needs evidence and another authorised verifier; changed supplier/training proof is flagged. Incident decisions record awareness, a reviewed applicable duty, verified deadline/recipient, rationale and receipt. Changed incident facts, source revisions or proof prevent stale closure. The software does not assume every incident has the same legal deadline.

Existing calendar, notification preferences, reminders and escalation facilities are reused. Stable source keys prevent duplicate review events; changing a date updates its event. Readership acknowledgement completes its event. Actual external delivery remains conditional on configured and tested providers.

Security work adds metadata-only tenant/global history, linked hashes and append protection, with restricted runtime grants and a separate provisioning pool. Upload confirmation checks stored size and format, supports safe retries and preserves successful uploads when OCR is unavailable. Office preview defaults off and needs explicit consent if enabled. CSV formula-leading text is neutralised. Refresh races no longer undo a newer sign-in or resurrect a signed-out session.

New tables support absent consultations, source versions, tests, readership receipts, risk/control links, risk reviews, supplier answers and event metadata. Existing organisations, people, controls, policies, risks, audits, findings, incidents, evidence and tasks are linked by stable IDs; duplicate master modules were not created. Source_Changes.csv and the selected patch list modified/new components.

## Verification and data preservation

Verification_Summary.json and the selected receipts record the actual results. Private credentials, native cloud backups and customer row values are excluded from this review pack. The unit run passed 50 tests; its 40 database-dependent skips were subsequently executed in a separate disposable database. Use the separate integration receipt for those results.

Workflow integration checks cover independence, refusal paths, stale files/snapshots, exact policy-version readership, remaining-risk review, CAPA/finding closure, incident reopening, supplier/training proof, ledger protection and application tenant boundaries. The assessment journey checks consultation through independent sign-off and the real three-sheet workbook.

HTTP checks exercise eight roles, permission-appropriate queues/counts, actual form downloads, global actor stamping, cross-tenant refusal and new-organisation provisioning with the restricted runtime. Browser checks visit 37 owner pages at desktop and phone widths, check eight roles, open key forms and save actual Word downloads. A separate multi-user browser journey creates, refuses self-approval, independently approves and revises an obligation while retaining approved source history. Auth tests cover delayed failure/success, sign-out and normal cookie restoration.

The synthetic upload journey verifies stored bytes, completed version, matching download, control link, read-only refusal and removal. Format checks are not antivirus or arbitrary-document sanitisation. Live OCR, email/SMS/push, SSO and object-store recovery are separate environment-specific acceptance checks.

The read-only PostgreSQL 18 native cloud backup restored 501 application tables and 3,230 rows with matching fingerprints. The original full backup retains every extension. The local drill omitted only two unused vector-extension TOC entries after confirming zero application vector columns. Windows UTF8/C collation differs from production. This proves logical application-data recovery, not an identical full-server or evidence-bucket recovery.

The first migration rehearsal preserved all original columns/rows across the restored database and 11 tenant schemas. The final repeat also verifies the already-upgraded copy. Validation executes DDL and rolls back. No production migration was executed.

## Deployment procedure

Use the existing Railway API and Vercel frontend projects. Preserve current licensing, signing/encryption keys, cookie settings, payment credentials, tenant IDs and evidence bucket. Do not reset a database, replay database/schema.sql or run prisma db push as part of this release.

1. Review the selected patch, manifest, tests and manual gates. Obtain explicit production-write approval, identify the operator and maintenance window, and record current source/environment revisions and both deployment IDs. Refresh the compatible native backup immediately before the change. Retain its checksum privately and back up/version the evidence bucket separately.

2. Build reviewed source in backend/frontend with the existing lockfiles and environment. Test against restored staging data and staging storage. No verification script in this pack authorises customer writes, live payments or external messages.

3. In backend, load the operator connection into PROVISIONING_DATABASE_URL without echoing it. Run node scripts/step2-release-migrations.mjs for the read-only plan. Run --validate on a reviewed restored/staging copy; it executes DDL then rolls back. Validation acquires locks and should not be run casually against production.

4. After approval and a fresh backup, run node scripts/step2-release-migrations.mjs --apply --production-change-approved. It applies only global 014 and tenant templates 015/016 in one transaction, recording migration 014. A failure rolls back the set. Lock timeout is 5 seconds and statement timeout 90 seconds. Investigate failures while retaining the previous release.

5. Existing billing tables are a prerequisite. A fresh installation needs the existing global/billing bootstrap before the final release migration. Do not invoke the historic billing initialiser as a production release shortcut; it contains one-time pricing logic requiring separate review. This release does not change

customer prices/plans.

6. Preview node scripts/prepare-runtime-identity.mjs. After explicit approval, use --apply --production-change-approved with an unused reviewed RUNTIME_DATABASE_ROLE to create the restricted login/grants. It refuses to overwrite an existing role/password. Test in staging and load generated private credentials through the existing secret manager; never commit or share the credential file.

7. Set DATABASE_URL to the restricted runtime, PROVISIONING_DATABASE_URL to the protected operator credential and RUNTIME_DATABASE_ROLE to the runtime login. Apply scoped grants to all active schemas. New tenant provisioning uses the separate DDL pool and grants its schema transactionally. Startup skips legacy billing DDL when the provisioning connection is configured, so operator preparation must be complete.

8. Keep ALLOW_EXTERNAL_DOCUMENT_PREVIEW=false unless the organisation authorises external viewing. OCR_PROVIDER=none supports intentional OCR disablement. Otherwise verify storage, Redis, workers and Textract permissions. Test actual provider delivery/retries and notification preferences with an explicitly authorised synthetic recipient.

9. Deploy the API, verify health, then deploy the compatible frontend from the reviewed source. Check the supplied demo address, login/reload/logout, organisation switching, roles, synthetic file roundtrip, independent review and work queues. Confirm the published asset revision contains no stay-signed-in prompt. Avoid real customer mutations for demonstration.

## Rollback and recovery

Normal rollback restores the recorded prior API/frontend deployments together. Leave additive tables/columns and new history in place; do not drop them or discard post-release work. If runtime grants cause an outage, correct the specific grant through the secured operator process. A temporary return to an old identity requires a recorded security decision and expiry.

The release validation transaction always rolls back; an apply failure rolls back before commit. There is deliberately no destructive down script dropping source/test/reader/audit records. Application rollback with retained additive structures is the reversible path.

Restore a verified dump into a fresh isolated database first. Check PostgreSQL major, extensions, collation, fingerprints, encryption keys and actual evidence objects/versions. Test the application before requesting an approved production connection switch. Restore-over-live requires explicit separate approval. restore.sh prompts before destructive replacement; it is an emergency procedure, not the normal release rollback.

## Operational support runbook

Daily: check API/worker health, failed delivery/OCR jobs, storage access, pending reviews, overdue work and backup status. Weekly: sample a duty-control-evidence-test-finding-action chain and review privileged access. Monthly: rehearse isolated recovery, inspect retention/erasure requests and confirm official-source review owners.

Upload problem: inspect object existence and version upload status first; retry confirmation rather than creating duplicate evidence. A completed file can be used even when OCR is queued or disabled. Avoid document content or credentials in support logs.

Logout problem: check deployed asset revision, cookie domain/Secure/SameSite settings, API clock and revocation. Collect request IDs and status codes, never bearer tokens. Do not bypass revocation or extend sessions merely to suppress a failure.

Queue/link problem: compare the same organisation, role, attention filter and page. Workspaces paginate 200 records; pickers search beyond the initial list. Check responsibility/permissions instead of granting everyone administrator access.

Source change: revise the existing obligation, preserve history and resubmit. Review affected mappings, policies, notification decisions and assessment sign-offs. A risk acceptance cannot override a mandatory duty. An old library label does not establish that an edition is current or applicable.

## Outstanding acceptance and security limits

Production migration, restricted-identity configuration and deployment remain pending approval. Local restricted-runtime tests do not mean the current live superuser connection has already been replaced.

The shared runtime serves multiple tenant schemas. Tenant boundaries are enforced through authenticated tenant resolution and scoped application queries; this is not a separate database credential per customer. A database administrator can alter/drop history or triggers. Append protection and hash chains are not externally anchored WORM storage.

History captures event/actor/link metadata and selected states, not every old free-text or document body. Some legacy/background raw global operations may be attributed to system. Source, policy and test snapshots preserve their respective business content. This is not complete forensic capture of every interaction.

The organisation must select jurisdictions/sectors/licences, independent reviewers, risk acceptance authority, licensed full standards, retention/holds and recovery objectives. Official source review is a human responsibility. No automatic legal conclusion or certification is supplied.

Environment-specific acceptance remains for live OCR and communications, SSO, provider outage/retry recovery, payment-provider sandbox checks and evidence-bucket restore. Unconfigured/coming-soon connectors remain labelled. Local fixtures disabled external transports; no actual charge or external message was sent.

Full WCAG keyboard/screen-reader review, enterprise-volume performance, legal-hold automation, secure media destruction, external immutable archive and bulk untrusted imports are not demonstrated. Optional forms are editable working documents, not automatic new-register imports. Record an acceptance owner for each required operational gate before promising it.